

Fire Crow Audit Report

Continuous Offensive Security & SAST Agent Analysis

Job ID:	job-leak
Repository URL:	https://github.com/example/leaky-secrets-repo
Branch:	main
Audit Date:	June 07, 2026
Total Findings:	3

Executive Summary

OVERALL POSTURE: CRITICAL RISK

Fire Crow completed an authorization-only defensive security review of the submitted repository and recorded evidence-backed findings from the configured scanners.

1
CRITICAL

1
HIGH

1
MEDIUM

0
LOW

Summary Table of Findings

ID	Title	Severity	Source	CWE
FC-001	[SIMULATED] Hardcoded GitHub OAuth Secret Leak	CRITICAL	SAST	N/A
FC-002	[SIMULATED] Outdated dependency with known CVE	MEDIUM	DEPENDENCY_SCAN	CWE-200
FC-003	[SIMULATED] Hardcoded Secret or Insecure Deserialization	HIGH	SEMGREP	CWE-502

Scanner Execution Evidence

Scanner	Status	Mode	Tool
Recon	executed	simulated	git
Regex SAST	executed	regex	built-in regex
Semgrep	executed	simulated	semgrep
Dependency scan	executed	simulated	osv-scanner/trivy
Dynamic validation	not recorded	not recorded	N/A
Sandbox mode	not recorded	not recorded	N/A

Detailed Findings & Proofs

FC-001 [SIMULATED] Hardcoded GitHub OAuth Secret Leak

CRITICAL

Source Agent: SAST | CWE Link: N/A | CVSS: N/A (N/A)

VULNERABILITY DESCRIPTION

A raw GitHub client secret was found hardcoded in main.py

Evidence Sample

```
scanner_name=sast-fixture; scanner_mode=simulated; confidence=low
```

REMEDIATION GUIDANCE

Move secrets to environment variables and rotate key immediately.

FC-002 [SIMULATED] Outdated dependency with known CVE

MEDIUM

Source Agent: DEPENDENCY_SCAN | CWE Link: [CWE-200](#) | CVSS: N/A (N/A)

VULNERABILITY DESCRIPTION

Debug-mode simulated dependency finding. Production reports only include dependency findings from configured scanners such as osv-scanner or trivy.

Evidence Sample

```
scanner_name=dependency-simulation; scanner_mode=simulated; confidence=low  
package=requests; version=2.28.1
```

REMEDIATION GUIDANCE

Follow standard secure coding patterns, validate all entry points, and sanitise parameters.

FC-003 [SIMULATED] Hardcoded Secret or Insecure Deserialization HIGH

Source Agent: SEMGREP | CWE Link: [CWE-502](#) | CVSS: N/A (N/A)

VULNERABILITY DESCRIPTION

Debug-mode simulated Semgrep finding. Production reports only include Semgrep findings when the semgrep CLI executes successfully.

Evidence Sample

```
scanner_name=semgrep-simulation; scanner_mode=simulated; confidence=low  
rule_id=debug.simulated.yaml-load
```

REMEDIATION GUIDANCE

Review the affected code and apply standard security best practices to mitigate this vulnerability.